WAF++

Architecture Review Report

Architecture Review Report

Infrastructure Security & Compliance Assessment

Checked path	../dummy_code
Report date	2026-03-15 13:14 UTC
Controls loaded	32
Controls run	32
Tool version	WAF++ PASS v0.1.0

9	19	4
PASS	FAIL	SKIP

Executive Summary

Metric	Controls	Checks
✓ Passed	9	83
✗ Failed	19	53
■ Skipped	4	35
Total	32	171

Pillar Breakdown

Pillar	✓ Pass	✗ Fail	■ Skip
Cost	2	6	1
Security	5	5	3
Sovereign	2	8	0

Controls Overview

All evaluated controls with their overall result. Detailed findings for failed controls follow in the next section.

ID	Title	Pillar	Severity	Status	✓	✗	■
WAF-COST-010	Cost Allocation Tagging Enforced	Cost	HIGH	FAIL	10	4	1
WAF-COST-020	Cost Budgets & Alerting Configured	Cost	HIGH	PASS	2	0	1
WAF-COST-030	Resource Rightsizing & Idle Detection	Cost	MEDIUM	FAIL	0	1	1
WAF-COST-040	Storage & Retention Lifecycle Defined	Cost	HIGH	FAIL	6	1	0
WAF-COST-050	Cost Impact Assessment in Architecture Dec…	Cost	HIGH	SKIP	0	0	1
WAF-COST-060	FinOps Review Cadence	Cost	MEDIUM	FAIL	0	2	0
WAF-COST-070	Observability & Logging Cost Tiers	Cost	MEDIUM	FAIL	9	1	0
WAF-COST-080	Commitment & Reserved Capacity Planning	Cost	MEDIUM	FAIL	0	1	1
WAF-COST-090	Data Transfer & Egress Cost Management	Cost	HIGH	PASS	2	0	0
WAF-SEC-010	Identity & Access Management Baseline	Security	CRITICAL	FAIL	0	1	0
WAF-SEC-020	Least Privilege & RBAC Enforcement	Security	CRITICAL	PASS	4	0	0
WAF-SEC-030	Encryption at Rest with Customer-Managed K…	Security	HIGH	FAIL	1	1	0
WAF-SEC-040	Encryption in Transit – TLS Enforcement	Security	HIGH	SKIP	0	0	2
WAF-SEC-050	Network Segmentation & Security Group Hard…	Security	HIGH	PASS	1	0	2
WAF-SEC-060	Secrets Management – No Hardcoded Credenti…	Security	CRITICAL	FAIL	2	2	0
WAF-SEC-070	Vulnerability & Patch Management	Security	MEDIUM	SKIP	0	0	2
WAF-SEC-080	Security Monitoring & Threat Detection	Security	HIGH	PASS	3	0	0
WAF-SEC-090	Policy-as-Code & Compliance Automation	Security	MEDIUM	PASS	1	0	1

WAF-SEC-100	Incident Response Readiness	Security	MEDIUM	FAIL	0	5	1
WAF-SEC-110	Supply Chain Security & SBOM	Security	HIGH	SKIP	0	0	2
WAF-SEC-120	Container & Runtime Security	Security	HIGH	PASS	1	0	1
WAF-SEC-130	Data Classification & Sensitive Data Prote…	Security	HIGH	FAIL	2	6	0
WAF-SOV-010	Data Residency Policy Defined	Sovereign	HIGH	FAIL	4	2	2
WAF-SOV-020	Region Pinning Enforced (IaC)	Sovereign	CRITICAL	PASS	16	0	1
WAF-SOV-030	Backup Location & Retention Controlled	Sovereign	HIGH	FAIL	0	2	4
WAF-SOV-040	Logging & Telemetry Residency Controlled	Sovereign	HIGH	FAIL	3	10	0
WAF-SOV-050	Key Ownership & Management Defined	Sovereign	CRITICAL	FAIL	2	5	1
WAF-SOV-060	Privileged Access Controlled (Separation o…	Sovereign	CRITICAL	FAIL	4	1	3
WAF-SOV-070	Break-Glass Process & Logging	Sovereign	HIGH	PASS	2	0	3
WAF-SOV-080	Dependency & Subprocessor Inventory	Sovereign	MEDIUM	FAIL	1	1	2
WAF-SOV-090	Controlled Egress & Data Exfiltration Guar…	Sovereign	HIGH	FAIL	2	2	2
WAF-SOV-100	Exit Plan & Portability Tested	Sovereign	MEDIUM	FAIL	5	5	1

Findings

19 control(s) produced findings that require attention. Each finding includes the affected resource, the specific violation, and remediation guidance.

WAF-COST-010 Cost Allocation Tagging Enforced

HIGH

All cloud resources MUST carry mandatory cost allocation tags: cost-center, owner, environment, and workload. These tags are required on all resource types that generate billable costs (compute, storage, database, network, managed services). Tagging MUST be enforced in the CI/CD pipeline; deployments without full tag compliance MUST be blocked or f…

FAIL	`aws_instance.web`	Resource is missing the mandatory 'cost-center' tag.; Resource is missing the mandatory 'owner' tag.
FAIL	`aws_eks_node_group.main`	Resource is missing the mandatory 'workload' tag.
FAIL	`aws_elasticache_cluster.session`	Resource is missing the mandatory 'owner' tag.; Resource is missing the mandatory 'workload' tag.
FAIL	`aws_s3_bucket.logs_raw`	Resource is missing the mandatory 'cost-center' tag.; Resource is missing the mandatory 'owner' tag.; Resource is missing the mandatory 'workload' tag.

→ **Remediation:** Use the shared mandatory-tags module to generate the complete tag map. Add module "tags" { source = "../../modules/mandatory-tags"; cost_center = ...; owner = ...; environment = ...; workload = ...; } Then set tags = module.tags.tags on every resource.

WAF-COST-030 Resource Rightsizing & Idle Detection

MEDIUM

All persistent compute resources (EC2 instances, VMs, RDS instances, Kubernetes node groups) MUST carry a 'rightsizing-reviewed' tag with the date of the last review (ISO 8601, YYYY-MM-DD). Reviews must be performed at least every 90 days. Resources tagged with a review date older than 90 days are considered non-compliant. Idle detection must be co…

FAIL	`aws_instance.web`	EC2 instance is missing the 'rightsizing-reviewed' tag. All compute resources must be actively reviewed.

→ **Remediation:** Add 'rightsizing-reviewed' tag to all EC2 instances and launch templates. Value format: YYYY-MM-DD (ISO 8601 date of last review). Example: rightsizing-reviewed = "2025-03-01" Schedule the next review within 90 days.

WAF-COST-040 Storage & Retention Lifecycle Defined

HIGH

All storage resources (S3 buckets, Azure Storage accounts, GCS buckets) MUST have explicit lifecycle rules configured. All log groups (CloudWatch, Azure Log Analytics, GCP Cloud Logging) MUST have an explicit retention_in_days value that is not 0 (infinite) and not null. No storage or logging resource may be provisioned without an explicit, finite …

FAIL	`aws_cloudwatch_log_group.debug_logs`	retention_in_days must be >= 1. Setting 0 means infinite retention (WAF-COST-040 violation).

→ **Remediation:** Set retention_in_days on all aws_cloudwatch_log_group resources. Use the 4-tier model: operational=30, security-audit=365, compliance=2555 (7yr). Never use 0 (infinite) as this represents unconstrained cost debt.

WAF-COST-060 FinOps Review Cadence

MEDIUM

Monthly engineering-level FinOps reviews MUST take place for all production workloads. Quarterly Architecture Board reviews covering cost debt and strategic cost decisions MUST occur. Review outputs (action items with owner and due date) MUST be documented in writing and accessible in the team's task tracking system. Reviews are mandatory, not opti…

FAIL	`aws_instance.web`	Resource is missing 'last-finops-review' tag. Monthly FinOps reviews required.
FAIL	`aws_eks_cluster.main`	Resource is missing 'last-finops-review' tag. Monthly FinOps reviews required.

→ **Remediation:** After each monthly FinOps review, update the 'last-finops-review' tag on workload resources to the current date. This can be automated in CI as part of the review process. Value format: YYYY-MM-DD.

WAF-COST-070 Observability & Logging Cost Tiers

MEDIUM

Logging and observability resources MUST be organized in explicit retention tiers: Hot (7-30 days), Warm (30-90 days), Cold (90-365 days), Archive (>365 days). CloudWatch Log Groups MUST NOT have retention_in_days = 0 (infinite). Operational log groups MUST have retention_in_days <= 365. DEBUG-level logging in production is prohibited without Archi…

FAIL	`aws_cloudwatch_log_group.debug_logs`	retention_in_days must be >= 1. Value 0 means infinite retention (cost debt).

→ **Remediation:** Set retention_in_days on all aws_cloudwatch_log_group resources. Recommended values by tier: operational=30, access=90, security-audit=365. Compliance-driven long retention: use S3 export + lifecycle instead of CloudWatch.

WAF-COST-080 Commitment & Reserved Capacity Planning

MEDIUM

Compute resources with sustained utilization >= 70% over 30 days MUST be covered by Reserved Instances or Savings Plans. All persistent on-demand compute resources MUST carry a 'capacity-commitment' tag documenting their reservation status and the date of the last commitment review. Spot/Preemptible Instances are the preferred option for variable a…

FAIL	`aws_instance.web`	EC2 instance missing 'capacity-commitment' tag. Reservation status must be declared.; capacity-commitment must be: reserved, savings-plan, spot, on-demand, or reviewed.

→ **Remediation:** Add 'capacity-commitment' tag to all EC2 instances. Value 'reserved' or 'savings-plan' = commitment exists. Value 'on-demand' = no commitment, flagged for review. Value 'reviewed' = reviewed and consciously left on-demand (needs date + justification).

WAF-SEC-010 Identity & Access Management Baseline

CRITICAL

All AWS accounts MUST enforce MFA for all IAM users with console access. Root account usage MUST be prohibited for day-to-day operations. IAM password policy MUST meet minimum security requirements: minimum length of 14 characters, complexity requirements, password reuse prevention of at least 5 prior passwords, and maximum password age of 90 days.…

FAIL	`aws_iam_account_password_policy.main`	IAM password policy must require a minimum of 14 characters.; IAM password policy must prevent reuse of at least 5 prior passwords.; IAM password policy must set maximum password age to 90 days or less.

→ **Remediation:** Define an aws_iam_account_password_policy resource with all required attributes set. Ensure minimum_password_length >= 14, all require_* flags are true, password_reuse_prevention >= 5, and max_password_age <= 90.

WAF-SEC-030 Encryption at Rest with Customer-Managed Keys

HIGH

All data stores containing sensitive or classified data MUST be encrypted at rest using customer-managed keys (CMK) stored in AWS KMS. Automatic key rotation MUST be enabled for all CMKs. Encryption using only provider-managed keys (SSE-S3/AES256) is NOT sufficient for sensitive, PII, financial, or regulated data. KMS key deletion windows MUST be s…

FAIL	`aws_kms_key.main`	KMS key deletion window must be at least 7 days to allow recovery from accidental deletion.

→ **Remediation:** Set enable_key_rotation = true on all aws_kms_key resources. Set deletion_window_in_days to at least 7 (recommend 30 for production keys). Note: key rotation does not apply to asymmetric keys or keys in external key stores; those require separate rotation procedures.

WAF-SEC-060 Secrets Management – No Hardcoded Credentials

CRITICAL

All secrets, API keys, passwords, database credentials, and certificates MUST be stored in a dedicated secrets management solution (AWS Secrets Manager or HashiCorp Vault). Secrets MUST NOT be hardcoded in IaC code, Terraform variable files, environment variables in task definitions, source code, or CI/CD pipeline configuration. Secrets Manager sec…

FAIL	`aws_secretsmanager_secret.db_password`	Secrets Manager secret recovery window must be at least 7 days to allow recovery from accidental deletion.
FAIL	`aws_secretsmanager_secret.api_key`	Secrets Manager secret recovery window must be at least 7 days to allow recovery from accidental deletion.

→ **Remediation:** Add name and recovery_window_in_days = 30 to all aws_secretsmanager_secret resources. Do not set force_overwrite_replica_secret = true or recovery_window_in_days = 0 unless in a controlled testing environment.

WAF-SEC-100 Incident Response Readiness

MEDIUM

An incident response (IR) plan MUST exist, be documented, version-controlled, and tested at least annually via tabletop exercises or simulated incident drills. SNS topics or equivalent alerting channels MUST be configured to receive security findings from GuardDuty, Security Hub, and CloudTrail metric alarms. Security-relevant CloudWatch log groups…

FAIL	aws_cloudwatch_log_group.cloudtrail	Security-relevant log groups MUST retain logs for at least 365 days to support forensic investigation and regulatory compliance.
FAIL	aws_cloudwatch_log_group.app_logs	Security-relevant log groups MUST retain logs for at least 365 days to support forensic investigation and regulatory compliance.
FAIL	aws_cloudwatch_log_group.access_logs	Security-relevant log groups MUST retain logs for at least 365 days to support forensic investigation and regulatory compliance.
FAIL	aws_cloudwatch_log_group.debug_logs	Security-relevant log groups MUST retain logs for at least 365 days to support forensic investigation and regulatory compliance.
FAIL	aws_cloudwatch_log_group.vpc_flow_logs	Security-relevant log groups MUST retain logs for at least 365 days to support forensic investigation and regulatory compliance.

→ **Remediation:** Set retention_in_days = 365 (or higher) on all security-relevant aws_cloudwatch_log_group resources. For CloudTrail and VPC Flow Logs with higher volume, consider using S3-based retention with lifecycle policies (Standard for 12 months, Glacier for 7 years) rather than CloudWatch to optimize cost.

WAF-SEC-130 Data Classification & Sensitive Data Protection

HIGH

All data-storing resources (S3 buckets, RDS instances, DynamoDB tables, ElastiCache clusters) MUST carry a 'data-class' tag indicating the sensitivity level (e.g., public, internal, confidential, pii, health, financial). Resources classified as 'pii', 'health', or 'financial' MUST be encrypted with a customer-managed KMS key (CMK). Database instanc…

FAIL	aws_db_instance.main	Data-storing resource MUST carry a 'data-class' tag (e.g., public, internal, confidential, pii, health, financial).
FAIL	aws_elasticache_cluster.session	Data-storing resource MUST carry a 'data-class' tag (e.g., public, internal, confidential, pii, health, financial).
FAIL	aws_s3_bucket.data_lake	Data-storing resource MUST carry a 'data-class' tag (e.g., public, internal, confidential, pii, health, financial).
FAIL	aws_s3_bucket.logs_raw	Data-storing resource MUST carry a 'data-class' tag (e.g., public, internal, confidential, pii, health, financial).
FAIL	aws_s3_bucket.backups	Data-storing resource MUST carry a 'data-class' tag (e.g., public, internal, confidential, pii, health, financial).
FAIL	aws_s3_bucket.cloudtrail	Data-storing resource MUST carry a 'data-class' tag (e.g., public, internal, confidential, pii, health, financial).

→ **Remediation:** Add a 'data-class' tag to all data-storing resources with a value from the approved classification taxonomy (e.g., "public", "internal", "confidential", "pii", "health", "financial"). Enforce mandatory tagging via an AWS Config rule (required-tags) or an SCP denying CreateBucket, CreateDBInstance, CreateTable API calls without the required tag. Implement a tagging standard in your Terraform module library to make compliant resource creation the default path.

WAF-SOV-010 Data Residency Policy Defined

HIGH

A documented data-residency policy MUST exist that explicitly defines allowed regions, data classifications, and storage rules for all data types: primary data, replicas, backups, logs, traces, metrics, and metadata. The policy MUST be version-controlled and technically reflected in IaC defaults and variable validation.

FAIL	aws_elasticache_cluster.session	Resource is missing the 'data-residency' tag required by sovereignty policy.; Resource is missing the 'data-class' tag required by data classification policy.
FAIL	aws_s3_bucket.logs_raw	Resource is missing the 'data-residency' tag required by sovereignty policy.; Resource is missing the 'data-class' tag required by data classification policy.

→ **Remediation:** Add 'data-residency' and 'data-class' tags to all data-storing resources. Acceptable values for 'data-residency': eu-only, de-only, ch-only, at-only, global-approved. Acceptable values for 'data-class': pii, health, financial, operational, public, restricted.

WAF-SOV-030 Backup Location & Retention Controlled

HIGH

Backup policies MUST explicitly define region/location constraints, minimum retention periods, and restore-test schedules. Cross-region replication MUST be explicitly configured and documented with an approved sovereign destination. Backup storage MUST remain within the same jurisdictional boundary as primary data unless explicitly approved and doc…

FAIL	aws_db_instance.main	RDS backup_retention_period must be >= 7 days for sovereign compliance.
FAIL	aws_s3_bucket_versioning.data_lake	S3 bucket versioning must be Enabled for backup/sovereign data stores.

→ **Remediation:** Set backup_retention_period to at least 7 (days) on all production RDS instances and 30 days for instances processing PII or financial data.

WAF-SOV-040 Logging & Telemetry Residency Controlled

HIGH

All observability data—logs, traces, and metrics—MUST be stored in approved sovereign regions. Exports to external platforms (SaaS observability, third-party SIEM) MUST be explicitly approved, documented, and controlled. Log retention periods MUST be defined and enforced. VPC flow logs MUST be enabled to support forensic investigation within sovere…

FAIL	aws_cloudwatch_log_group.cloudtrail	Log group retention must be at least 30 days.
FAIL	aws_cloudwatch_log_group.app_logs	Log group retention must be at least 30 days.
FAIL	aws_cloudwatch_log_group.access_logs	Log group retention must be at least 30 days.
FAIL	aws_cloudwatch_log_group.debug_logs	Log group retention must be at least 30 days.
FAIL	aws_cloudwatch_log_group.vpc_flow_logs	Log group retention must be at least 30 days.
FAIL	aws_cloudwatch_log_group.cloudtrail	Audit/security log group should be encrypted with a customer-managed KMS key.
FAIL	aws_cloudwatch_log_group.app_logs	Audit/security log group should be encrypted with a customer-managed KMS key.
FAIL	aws_cloudwatch_log_group.access_logs	Audit/security log group should be encrypted with a customer-managed KMS key.

FAIL	aws_cloudwatch_log_group.debug_logs	Audit/security log group should be encrypted with a customer-managed KMS key.
FAIL	aws_cloudwatch_log_group.vpc_flow_logs	Audit/security log group should be encrypted with a customer-managed KMS key.

→ **Remediation:** Set retention_in_days on all CloudWatch log groups. Use 90 days minimum for audit and security logs, 30 days minimum for application logs.

WAF-SOV-050 Key Ownership & Management Defined

CRITICAL

For all data classes, the key ownership model MUST be explicitly defined and technically enforced: Provider-Managed Keys (PMK), Customer-Managed Keys (CMK), Bring Your Own Key (BYOK), or Hold Your Own Key (HYOK). Key rotation and deletion MUST be governed by documented procedures. All data at rest MUST be encrypted; encryption with default provider…

FAIL	aws_kms_key.main	KMS key deletion_window_in_days must be >= 14 days.
FAIL	aws_s3_bucket_server_side_encryption_configuration.data_lake	S3 bucket must use 'aws:kms' encryption, not 'AES256' (provider-managed keys).; S3 KMS encryption must reference a specific CMK, not the default AWS managed key.
FAIL	aws_s3_bucket_server_side_encryption_configuration.logs_raw	S3 bucket must use 'aws:kms' encryption, not 'AES256' (provider-managed keys).; S3 KMS encryption must reference a specific CMK, not the default AWS managed key.
FAIL	aws_s3_bucket_server_side_encryption_configuration.backups	S3 bucket must use 'aws:kms' encryption, not 'AES256' (provider-managed keys).; S3 KMS encryption must reference a specific CMK, not the default AWS managed key.
FAIL	aws_instance.web	EBS volume must have encrypted = true.

→ **Remediation:** Set deletion_window_in_days >= 14 on all KMS keys.

WAF-SOV-060 Privileged Access Controlled (Separation of Duties)

CRITICAL

Privileged roles MUST be minimized, time-bound, and subject to regular access reviews. Separation of Duties MUST be enforced: no single principal should be able to create infrastructure, approve deployments, AND manage encryption keys simultaneously. Wildcard IAM permissions ('*' on '*') are forbidden. Administrative access MUST use JIT (Just-In-Ti…

FAIL	aws_iam_account_password_policy.main	IAM password minimum length must be >= 14 characters.; IAM password policy must prevent reuse of at least 12 previous passwords.; IAM password max age must be <= 90 days.

→ **Remediation:** Configure an aws_iam_account_password_policy resource with strong password requirements.

WAF-SOV-080 Dependency & Subprocessor Inventory

MEDIUM

An inventory of all dependencies and subprocessors MUST be maintained: managed cloud services, third-party SaaS tools, CI/CD platforms, observability providers, and data processors. Changes to this inventory MUST be version-controlled, reviewed, and approved. Provider version constraints in Terraform MUST be pinned to prevent silent upgrades. Modul…

FAIL	terraform	Provider version constraint is too broad (>= 0.0.0). Use a tightly bounded constraint.

→ **Remediation:** Add version constraints to all required_providers using the ~> operator for compatible version pinning (e.g., ~> 5.0 for AWS provider v5.x).

WAF-SOV-090 Controlled Egress & Data Exfiltration Guardrails

HIGH

Outbound network traffic MUST be controlled using a default-deny or strict allow-list policy. Security groups must not permit unrestricted egress (0.0.0.0/0) without explicit justification. VPC endpoints MUST be used for access to cloud provider APIs to keep traffic on the sovereign network. Data exfiltration detection MUST be established to alert …

FAIL	aws_security_group.internal_app	Security group allows unrestricted outbound access to 0.0.0.0/0. Restrict to specific destinations.; Security group allows unrestricted outbound access to ::/0 (all IPv6).
FAIL	aws_security_group.public_alb	Security group allows unrestricted outbound access to 0.0.0.0/0. Restrict to specific destinations.; Security group allows unrestricted outbound access to ::/0 (all IPv6).

→ **Remediation:** Replace 0.0.0.0/0 egress rules with specific CIDR ranges or prefix lists. Use VPC endpoints for cloud service access to eliminate the need for internet egress.

WAF-SOV-100 Exit Plan & Portability Tested

MEDIUM

A documented exit plan MUST exist covering data export procedures, IaC portability strategy, dependency replacement mapping, timeline, and cost estimates. Exit/restore drills MUST be performed at least annually to validate that the exit plan is executable. IaC must use open standards and provider-agnostic patterns where feasible to reduce proprieta…

FAIL	aws_s3_bucket_versioning.data_lake	S3 bucket versioning must be Enabled for sovereign data portability.
FAIL	aws_s3_bucket.data_lake	Resource is missing 'portability-class' tag needed for exit orchestration.
FAIL	aws_s3_bucket.logs_raw	Resource is missing 'portability-class' tag needed for exit orchestration.
FAIL	aws_s3_bucket.backups	Resource is missing 'portability-class' tag needed for exit orchestration.
FAIL	aws_s3_bucket.cloudtrail	Resource is missing 'portability-class' tag needed for exit orchestration.

→ **Remediation:** Enable versioning on S3 buckets containing sovereign data.

Passed Controls

Control ID	Title	Checks passed
WAF-COST-020	Cost Budgets & Alerting Configured	2
WAF-COST-090	Data Transfer & Egress Cost Management	2
WAF-SEC-020	Least Privilege & RBAC Enforcement	4
WAF-SEC-050	Network Segmentation & Security Group Hardening	1
WAF-SEC-080	Security Monitoring & Threat Detection	3
WAF-SEC-090	Policy-as-Code & Compliance Automation	1
WAF-SEC-120	Container & Runtime Security	1
WAF-SOV-020	Region Pinning Enforced (IaC)	16
WAF-SOV-070	Break-Glass Process & Logging	2

Skipped Controls

The following controls were skipped — either no matching Terraform resources were found, or all assertions use operators not supported in automated evaluation.

Control ID	Title	Reason
WAF-COST-050	Cost Impact Assessment in Architecture Decisi…	No matching resources found in Terraform configuration.
WAF-SEC-040	Encryption in Transit – TLS Enforcement	No matching resources found in Terraform configuration.
WAF-SEC-070	Vulnerability & Patch Management	No matching resources found in Terraform configuration.
WAF-SEC-110	Supply Chain Security & SBOM	No matching resources found in Terraform configuration.